Module 1 Learner Guide: Threat Landscape and Legal Governance Frameworks

Oct 19, 2026 · @Nenji

Start here

This module helps everyone who handles information, not only IT staff, protect what citizens entrust to government. It runs 4 hours on the morning of Day 1 and ends with Quiz 1 (10% of your grade).

Item	Detail
Course	Protecting Digital Assets from Cyber Threats (DICT ILCDB, ICT Academy: Digital Workforce)
Pillar	Cybersecurity: Governance, Risk and Compliance (GRC), Beginner
Module	1 of 5: Threat Landscape and Legal Governance Frameworks
Dates	Face-to-face: Wednesday 21 to Friday 23 October 2026. Online: Monday 26 to Wednesday 28 October 2026
Time	4 hours on the morning of Day 1 (21 October face-to-face; 26 October online), 8:00 AM to 12:00 NN
Syllabus items	1.1, 1.2, 1.2.1, 1.2.2
Assessment	Quiz 1: 15 items, 20 minutes, closed book, 10%

Who this is for

If you collect, encode, file, approve, release or store information about people, this module is for you. That includes records and HR staff, finance and cashiers, frontline and social workers, managers, Data Protection Officers (DPOs) and IT personnel. You do not need a technical background. Parts marked **IT depth** are optional extras for technical staff.

What you will be able to do

Each level builds on the one before it, from remembering a fact to using it in your own office.

Level	By noon you will be able to	Where you practise
Remember	Recall Secret-Correct-Ready, the three privacy principles, the 3S breach test and the 72-5 deadlines	Check yourself; Quiz 1
Understand	Explain in your own words why government offices are attacked, and who is responsible for what under the Data Privacy Act	Lessons 1.1 and 1.2
Apply	Sort information into personal, sensitive personal, or not covered, and judge everyday situations as compliant or not	Try it 1.2A and 1.2B
Analyze	Break down a real incident into what failed and what the law required	Try it 1.1B (the 2023 ransomware case)
Evaluate	Decide whether a breach must be reported to the NPC, and defend your decision	Try it 1.2C
Create	Draft a rule for using AI tools in your unit, a map of how one process handles personal data, and your own action plan	Try it 1.2.2A; Bring it home
Experiment	Test what content credentials show on an original image and on a screenshot of it	Try it 1.2.2B

How each lesson works

- **Key idea:** the one sentence to remember.
- **Explain it like this:** an everyday comparison.
- **At your desk / In the server room:** what the idea means for people who handle data, and for people who run systems.
- **Try it:** a short activity. Its level (Apply, Analyze and so on) tells you what kind of thinking it builds.
- **Check yourself:** quick questions, with answers at the end of the guide. Answer before you look: trying to recall is what makes it stick.

The story we follow

Every example happens in one office, so you can see how the ideas connect. The office, its people and its data are fictional.

Regional Social Services Office (RSSO), fictional Region Q. Citizens apply for social assistance through its online Assistance Portal. It holds records of about 48,000 applicants: names, addresses, birthdates, government ID numbers, health information for medical assistance, and e-wallet numbers for payouts.

Person	Role	Handles
Director Eva	Head of office	Policies, budgets, public statements
Carla	Data Protection Officer and legal officer	Privacy compliance, reports to the NPC
Ana	IT officer	The portal, servers, accounts and backups
Ben	Records clerk	Encoding and filing applications
Dan	Cashier	Payouts and e-wallet lists
Sol	Social worker	Field visits and case notes

Session flow

Time	Segment
8:00 to 8:15	Opening, ground rules, privacy notice, teams
8:15 to 8:55	1.1 Modern cyber threats
8:55 to 9:05	Break
9:05 to 10:15	1.2 Data Privacy Act (RA 10173)
10:15 to 10:25	Break
10:25 to 10:55	1.2.1 ISO/IEC 27001
10:55 to 11:15	1.2.2 ASEAN Guide on AI Governance and Ethics
11:15 to 11:25	Questions and answers
11:25 to 11:50	Quiz 1 and answer review
11:50 to 12:00	Recap, Bring it home, afternoon preview

Ground rule: all cases in activities are fictional or already public. Please do not share real incidents, systems or people from your own office.

Lesson 1.1: Modern cyber threats and their impact on government operations

Key idea: attackers go after what your office holds: information people trusted you with, and services people depend on.

Most attacks start with a person, not a machine: an email opened, a password reused, a file sent the wrong way. That makes everyone in the office part of the defense.

Explain it like this: Secret, Correct, Ready

Every record your office keeps should stay **secret** from the wrong people, stay **correct**, and be **ready** when needed. Security specialists call these confidentiality, integrity and availability: the **CIA triad**.

Security term	Plain meaning	Everyday comparison	What losing it looks like at the RSSO
Confidentiality	Secret: only the right people can see it	A sealed envelope	Applicant records appear online
Integrity	Correct: no one changed it without permission	A receipt with an official stamp	An e-wallet number on the payout list is quietly changed
Availability	Ready: it works when people need it	An office that opens on time	The Assistance Portal is down for a week

Ask of anything you handle: what happens if it leaks, if someone changes it, or if it is gone for a week?

Who attacks, and why

Who	What they want	What they usually do
Criminal groups	Money	Lock files and demand payment (ransomware); steal data and threaten to publish it (extortion); trick staff into paying fake invoices
State-linked groups	Secrets and influence	Stay hidden for months to collect documents and personal data

Who	What they want	What they usually do
Hacktivists	Attention for a cause	Deface websites, flood them with traffic until they crash, post stolen data
Insiders	Gain, revenge, or simply convenience	Misuse their access, or move files to personal accounts to work faster
Vendors and partners	Usually nothing: they are the way in	Their weak account or system becomes the door into yours

Most harm from insiders is accidental, not malicious.

What the numbers say

- **Money drives most attacks.** Among attacks with a known motive in Microsoft's 2025 report, more than 52% involved extortion or ransomware and only 4% were espionage. Attackers tried to steal data in 80% of incidents (Microsoft, 22 October 2025).
- **The Philippines is a target.** It ranked 20th among the countries most affected by cyberattacks in the first half of 2025 (Interaksyon on Microsoft's report, 3 November 2025).
- **Passwords are the front door.** Identity-based attacks rose 32% in the first half of 2025, and more than 97% of them were password attacks (eSecurityPlanet on Microsoft's report). Multi-factor authentication (MFA), meaning a second proof such as a code on your phone, can block more than 99% of identity-based attacks (Microsoft).

How attackers get in: five doors

Door	What it looks like at your desk	What IT does about it
1. Phishing and stolen passwords	A message that rushes you to verify an account, open an attachment or change bank details	Email filtering, MFA, an easy way to report suspicious messages
2. Old or unpatched systems and lapsed licences	Warnings that updates or antivirus have expired	A patching schedule and renewals planned before expiry
3. Exposed websites and admin pages	Public pages or forms that show more than they should	Testing, hardening and monitoring of public systems

Door	What it looks like at your desk	What IT does about it
4. Shared accounts	One password for the whole unit, written on a note	One account per person; logs of who did what
5. Official files on personal apps	Lists and scanned IDs sent through personal email or chat groups	Approved tools that are easy enough that no one needs a workaround

Case study: ransomware at a national government agency, 2023

All facts below come from public news reports and an official NPC statement. The agency is not named, so we can focus on lessons, not blame.

When	What happened
A Friday in September 2023	The agency learned that ransomware had locked dozens of its computers. Its website and several online services for the public went down. The attackers demanded a ransom; the agency said it would not pay, in line with government protocol.
Three days later	The agency notified the NPC. The NPC asked it to explain, called it to a hearing, and scheduled an onsite investigation under Circular 16-03.
Four days later	The agency's initial investigation said no personal information had leaked.
About two weeks later	Stolen files began to appear online. The NPC examined the leaked files and found sensitive personal data. The agency advised the people affected to watch their accounts, change passwords and beware of phishing and smishing (phishing by text).
Seventeen days later	The agency confirmed that its antivirus subscription had expired in April 2023, five months before the attack; renewal had been delayed by procurement.

We study this case for its lessons, not to blame anyone. You will analyze it in Try it 1.1B.

Case study: September 2026 attacks and the 24-hour readiness check

- In early September 2026, DICT confirmed unauthorized access to one national agency's website and an unauthorized change to another agency's web host. For the second, initial assessments found no sensitive databases or personal data compromised. A reported ransomware attack on a third agency was investigated, and DICT found no evidence of ransomware or a breach.
- On 8 September 2026, DICT and the Cybercrime Investigation and Coordinating Center (CICC) placed national agencies, GOCCs, local government units and critical infrastructure operators on heightened cyber vigilance. Within 24 hours, each had to give its head of office a one-page cyber readiness assessment: the most serious risks, actions already taken, and help needed. Suspected serious incidents had to be reported immediately (as reported by Newsbytes, 10 September 2026).
- The priority measures were: fix critical weaknesses, require MFA for administrator accounts, reduce unnecessary internet exposure, improve monitoring, check that backups can actually be restored, review third-party access, and test incident response and continuity plans.

At your desk / In the server room

If you handle data	If you run systems
Pause when a message rushes you; verify through a number you already know	Turn on MFA, starting with email, VPN and administrator accounts
Never share your password; one account per person	Keep a list of systems and a calendar for patches and licence renewals
Use only approved tools for official files	Test that backups can be restored, not just that they run
Report anything odd at once, even if you are not sure	Make reporting easy and blame-free

Try it 1.1A: Secret, Correct, Ready (Apply, 8 minutes, teams)

For each RSSO asset, name the most likely threat, the property it hits first, and one thing your team would do.

RSSO asset	Most likely threat	Hit first: Secret, Correct or Ready?	One thing we would do
Applicant database			

RSSO asset	Most likely threat	Hit first: Secret, Correct or Ready?	One thing we would do
Payout list with e-wallet numbers			
Assistance Portal			
Office email			
Public website			
Backup drive			

Try it 1.1B: Read the 2023 case like an investigator (Analyze, 6 minutes)

1. Which of the five doors does the expired antivirus relate to?
2. Which of Secret, Correct and Ready were hit, and in what order?
3. The first statement said no personal data had leaked; two weeks later the NPC found sensitive data. What does that teach about waiting for certainty before reporting?
4. What could a non-IT employee have noticed, done, or reported?

Check yourself 1.1

1. Give the plain words for confidentiality, integrity and availability.
2. A hacktivist replaces the RSSO homepage with a protest message. Which property is hit first?
3. Why is a shared account a weakness even if no one misuses it?
4. What motive is behind most attacks?

Lesson 1.2: Data Privacy Act of 2012 (RA 10173)

Key idea: personal data is held in trust. Everyone who touches it must protect it, use it only for its purpose, and speak up fast when something goes wrong.

The Data Privacy Act (DPA) binds the people who handle data, not only the Data Protection Officer. Several DPA crimes, such as careless disposal of records or giving access through negligence, can be committed by any employee.

Explain it like this: data is money held in trust

When a citizen gives the RSSO their information, it is like handing over money for safekeeping. You may use it only for what it was given for. You keep it safe. You account for it when asked. If any of it goes missing, you report it at once.

What counts as personal data

Type	Plain meaning	RSSO examples
Personal information	Anything that identifies a person, on its own or combined with other details	Name with address; mobile number; photo; an applicant number linked to a name
Sensitive personal information	Personal information the law protects more strictly	Age, marital status, color, race or ethnic origin; religious, philosophical or political affiliation; health, education, genetic or sexual life; offenses and court cases; government-issued numbers such as social security numbers, licenses and tax returns; anything classified by law
Not covered	Information about a government employee that relates to their position or functions	Ben's name, title, office address and office phone on the citizen's charter; the salary range of a position; Ben's name on a document he prepared at work

So the RSSO may publish "Ben, Records Clerk, Records Unit". It may not publish Ben's home address or his health records. Sources: RA 10173, Sections 3(g), 3(l) and 4(a).

Who is who

Role	Plain meaning	At the RSSO
Data subject	The person the data is about	An applicant
Personal information controller (PIC)	Decides what data is collected and why	The RSSO itself
Personal information processor (PIP)	Handles data on the PIC's behalf, following its instructions	The SMS notification vendor; a contractor hired to encode forms
Data Protection Officer (DPO)	The person accountable for the office's compliance	Carla

Explain it like this: the RSSO owns the filing cabinet. A vendor it hires is a trusted helper who may open the cabinet only for the job and only as instructed. If the helper loses a file, the owner still answers to the citizen.

When may the office use personal data?

Only with a lawful reason. Government offices usually rely on their mandate under law (RA 10173, Section 12(e)) or, for sensitive information, on a law or regulation that requires the processing (Section 13(b)), not only on consent. Having a lawful reason does not switch off the rest of the law: the principles below, the security duties and people's rights still apply.

Three principles: Tell, Legit, Little

Principle	Memory word	Plain meaning	Ask yourself
Transparency	Tell	People know what you collect, why, and what you do with it	Did we tell applicants in a privacy notice?
Legitimate purpose	Legit	Use data only for the declared, lawful purpose	Am I using this list for what it was collected for?
Proportionality	Little	Collect and keep only what the purpose needs	Do we really need this field, this copy, for this long?

Source: RA 10173, Section 11.

What citizens can ask of you: their rights

Right	What it means at the counter
To be informed	Know that their data is being processed, why and how
To access	Get a copy of their data and details of how it is used
To object	Object to processing, for example to marketing or automated decisions
To rectification	Have errors corrected
To erasure or blocking	Have data removed or blocked on valid grounds

Right	What it means at the counter
To damages	Be compensated for harm caused by misuse
To data portability	Get their electronic data in a common format
To file a complaint	Complain to the National Privacy Commission (NPC)

After a person dies or becomes incapacitated, their lawful heirs can exercise these rights. Sources: RA 10173, Sections 16 to 18; NPC, Rights of a Data Subject.

At your desk: if a citizen asks to see or correct their record, do not refuse and do not improvise. Follow your office's procedure, or refer them to your DPO.

Keeping data safe: three kinds of measures

Kind	Plain meaning	Examples
Organizational	Rules, roles and routines	A privacy manual, a DPO, training, approvals, contracts with vendors
Physical	Places and things	Locked cabinets, a clean desk, a controlled server room, shredding
Technical	Settings and software	Strong passwords and MFA, encryption, backups, updates, activity logs

The DPA requires all three (Section 20). NPC Circular 2023-06, in effect since 30 March 2024 for both government and private offices, sets the minimum details (NPC; NPC FAQ). It replaced Circular 16-01 and includes:

- privacy by design and by default: build protection into forms and systems from the start;
- regular training of personnel;
- access rules, including the ability to remotely disconnect or delete data on mobile devices;
- a business continuity plan that covers backup and restoration;
- a ban on sending personal data by fax.

Extra rules for government offices

Rule	What the law says	Section
The head answers	Heads of agencies are responsible for securing the sensitive personal information their office holds	22
Security clearance	No employee may access sensitive personal information on government property or online without a security clearance from the head of the agency that holds it	23
Taking data off-site	Needs the head's approval. The head must decide within 2 business days; no answer means no	23
1,000-record limit	Approved off-site access covers no more than 1,000 records at a time	23
Encryption	Anything used to store, carry or access the data off-site must be encrypted to the standard the NPC recognizes	23
Contractors	A contractor handling sensitive personal information of 1,000 or more people for government must register its systems with the NPC and follow the same rules	24

Source: RA 10173, Sections 22 to 24.

At your desk: Ben wants to bring applicant files home on a USB stick to finish encoding. He needs the head's written approval, no more than 1,000 records at a time, and an encrypted USB stick.

When something goes wrong: breaches

A **personal data breach** is a security failure that destroys, loses or alters personal data, or lets someone see or take it without authority. NPC Circular 16-03 names three kinds, and they match Secret, Correct, Ready:

Kind of breach	What happened	Matches
Confidentiality breach	Data was disclosed or accessed without authority	Secret
Integrity breach	Data was altered	Correct
Availability breach	Data was lost or destroyed	Ready

A **security incident** is wider: any event that affects or could affect data protection, including near misses stopped in time. Report those too. Source: NPC Circular 16-03, Section 3.

Must we notify the NPC? The 3S test

Notify the NPC and the affected people when all three are true (Circular 16-03, Section 11):

1. **Sensitive:** the data is sensitive personal information, or information that could be used for identity fraud.
2. **Stolen:** there is reason to believe someone not authorized got hold of it (saw it, copied it or took it).
3. **Serious:** this is likely to cause a real risk of serious harm to the people affected.

When unsure, put the likelihood of harm first. Also weigh whether the breach involves 100 or more people, public safety or national security, information that the law requires to be confidential, or vulnerable groups (Section 13).

The 72-5 rule

Explain it like this: you call the fire department when you smell smoke, not when you see ashes. The clock starts when you know or reasonably believe a breach happened, not when you are certain.

Step	Rule	Source
Notify the NPC	Within 72 hours of knowing or reasonably believing that a breach happened	Circ. 16-03, Sec. 17
Notify the people affected	Within 72 hours, individually and through secure means. If that is not possible, the office must ask the NPC for an exemption or postponement	Sec. 18
Delay	Only as long as needed to find the scope, stop further disclosure or restore systems; never to hide the breach	Sec. 17
No delay allowed	When 100 or more people are affected, or disclosing sensitive information would harm them: notify within 72 hours using whatever you know	Sec. 17

Step	Rule	Source
Full report	Within 5 days from discovery, even while a request to the NPC is pending	Sec. 17; Advisory 2026-02
How to file	Breach notifications and annual incident reports go only through the NPC's online Data Breach Notification Management System (DBNMS). The full breach report goes to admindbnms@privacy.gov.ph, subject line FBR_NameofPIC_NameofDPO	NPC; Advisory 2026-02
Records	Document every incident, including those that need no notification, and send the NPC an annual summary	Sec. 22
If the NPC is silent	Silence is not approval; approvals are always in writing	Advisory 2026-02

At your desk: your job is to tell your DPO or IT right away. Deciding whether to notify the NPC belongs to the office's breach response team. Report even when you are unsure: concealing a breach is a crime in itself.

Why it is personal: selected penalties

Act	How it happens at an office	Personal information	Sensitive personal information	Section
Giving access through negligence	Leaving the system open on a shared computer; lending your password	1 to 3 years and P500,000 to P2 million	3 to 6 years and P500,000 to P4 million	26
Improper disposal	Throwing printed lists in the trash	6 months to 2 years and P100,000 to P500,000	1 to 3 years and P100,000 to P1 million	27
Unauthorized disclosure	Sending a list to someone with no right to it	1 to 3 years and P500,000 to P1 million	3 to 5 years and P500,000 to P2 million	32

Act	How it happens at an office	Personal information	Sensitive personal information	Section
Concealing a breach	Keeping quiet about a breach that must be reported	1 year 6 months to 5 years and P500,000 to P1 million	Same	30

- **Large scale:** when 100 or more people are affected, the maximum of the range applies (Section 35).
- **Public officers:** a government official or employee who commits an offense in the exercise of their duties is also disqualified from public office for twice the prison term (Section 36).
- The NPC can also impose administrative fines of up to P5 million per act under NPC Circular 2022-01.

Source: RA 10173, Sections 26, 27, 30, 32, 35 and 36. This summary is for training, not legal advice.

The government layer

- **Executive Order No. 58** (4 April 2024) adopted the National Cybersecurity Plan 2023-2028. National agencies and GOCCs must adopt aligned cybersecurity plans; LGUs are encouraged to.
- **DICT department circulars of 2024** (list): No. 003 on cybersecurity protection of government digital assets; No. 004 on a layered security and defense approach; No. 005 on reporting and mandatory disclosure of cybersecurity incidents; No. 006 on the Vulnerability Disclosure Initiative. Ask your ICT head how your office applies them.
- **Two reports, two regulators.** A personal data breach goes to the NPC. A cybersecurity incident is reported to DICT under its reporting mechanism. One event can need both.

Try it 1.2A: Sort the data (Apply, 5 minutes)

Mark each item P (personal), S (sensitive personal) or N (not covered by the DPA, or not personal information at all).

1. An applicant's full name and home address
2. An applicant's social security number
3. A medical certificate attached to a request for medical assistance
4. Ben's name and job title on the citizen's charter
5. An applicant's age and marital status

6. An applicant's mobile number and e-wallet number
7. A report saying "1,240 applicants this quarter, by province", with no names

Try it 1.2B: Compliant or not? (Apply and Evaluate, 10 minutes)

Vote compliant, not compliant, or it depends. Then give the reason.

1. A beneficiary list with ID numbers is shared as a public spreadsheet link.
2. A staff member emails the payroll file to a personal address to work from home.
3. A laptop with unencrypted HR files is stolen from a car.
4. A vendor gets full database access with no written agreement.
5. Citizen letters are pasted into a free public chatbot to draft replies.
6. The office website is defaced; the server held no personal data.

Try it 1.2C: Notify or not? (Evaluate, 10 minutes)

Apply the 3S test, decide, and defend your decision in one sentence.

1. Dan emails the payout list (230 names, e-wallet numbers and amounts) to the wrong outside address. The recipient replies that they deleted it.
2. Sol's laptop with case notes is stolen. Its disk is encrypted with a strong password that was not written down or stored with it.
3. Ransomware locks the Assistance Portal for two days. Ana's logs show no data left the network.

Check yourself 1.2

1. What do Tell, Legit and Little stand for?
2. Name two kinds of sensitive personal information.
3. What are the 3S?
4. When does the 72-hour clock start?
5. Ben wants to take 1,500 applicant records home. What does the law require?

Lesson 1.2.1: ISO/IEC 27001 overview

Key idea: ISO/IEC 27001 turns "we should be careful" into a yearly routine that you can show to an auditor.

The DPA tells you what to protect and when to report. ISO/IEC 27001 is the international standard for an **information security management system (ISMS)**: an organized way to decide which protections you need, put them in place, check that they work, and improve

them. An organization can be certified against it. Two related standards help: ISO/IEC 27002 explains how to apply each control, and ISO/IEC 27701 covers privacy; its 2025 edition can be used on its own, without ISO 27001 (Kiwa, January 2026).

Explain it like this: the yearly planning and budget cycle

Every year your office plans, carries out the plan, checks the results and adjusts. ISO 27001 applies the same cycle, called plan-do-check-act, to information security. Its clauses 4 to 10 are seven questions:

Clause	Plain question	Cycle step
4 Context of the organization	What do we protect, for whom, and what affects us?	Plan
5 Leadership	Does top management lead, set the policy and assign roles?	Plan
6 Planning	What are our risks and objectives, and which controls do we need?	Plan
7 Support	Do we have the people, skills, awareness and documents?	Do
8 Operation	Are we doing what we planned?	Do
9 Performance evaluation	Is it working? We monitor, audit and review	Check
10 Improvement	What do we fix and improve?	Act

The **Statement of Applicability (SoA)** is the office's checklist of all Annex A controls: which ones apply, which do not, and why.

Annex A: 93 controls in four themes: Rules, People, Places, Tech

Theme	Memory word	Controls	Plain meaning	Examples (control number)
Organizational	Rules	37	Policies, roles and routines	5.9 Inventory of information and other associated assets; 5.15 Access control; 5.24 to 5.28 Incident management, including 5.28 Collection of evidence

Theme	Memory word	Controls	Plain meaning	Examples (control number)
People	People	8	Screening, training and behaviour	6.3 Information security awareness, education and training; 6.7 Remote working
Physical	Places	14	Rooms, locks and equipment	7.9 Security of assets off-premises
Technological	Tech	34	Systems and settings	8.5 Secure authentication; 8.13 Information backup; 8.24 Use of cryptography

Memory aid: 37 + 8 + 14 + 34 = 93. Sources: Scrut; CertPro control list.

How ISO 27001 and the DPA fit together

The DPA and NPC ask for...	ISO 27001 helps you...
Organizational, physical and technical security measures (RA 10173, Sec. 20)	Choose them through a risk assessment and record the choices in the SoA
A breach response team, documentation and reports (Circular 16-03)	Run incident management and evidence collection (5.24 to 5.28)
Regular staff training (Circular 2023-06)	Run and measure awareness and training (6.3)
Backup, restoration and business continuity (Circular 2023-06)	Back up information and test restoration (8.13), within the continuity plan

For your office

Alignment is not certification. A practical start: list your information assets, find the top risks (Module 2 this afternoon), choose controls, give each one an owner, and check once a year.

IT depth: keep the SoA as a living document. Map each control to evidence (a policy, a log, a screenshot), so an audit or an NPC compliance check takes hours, not weeks.

Try it 1.2.1: Which theme would have caught it? (Apply and Analyze, 5 minutes)

Match each incident to Rules, People, Places or Tech.

1. A former contractor's account was still active three months after the contract ended.
2. A clerk opened a fake invoice attachment; no one had trained staff to spot one.
3. The server room key hangs beside the door, and no one logs who takes it.
4. The portal's login page did not encrypt passwords in transit.
5. When a breach was reported, no one knew which systems held citizen ID numbers.

Check yourself 1.2.1

1. Name the four themes and how many controls each has.
2. What does the Statement of Applicability record?
3. Which clause asks "Is it working?"

Lesson 1.2.2: ASEAN Guide on AI Governance and Ethics

Key idea: treat an AI tool like a new assistant: check its work, never hand it data it should not see, and keep a human responsible for every decision about a person.

Many staff already use free AI chatbots to draft letters or summarize documents. Pasting citizen data into a public tool can be an unauthorized disclosure under the DPA.

What the guide is

- A **voluntary** guide unveiled at the 4th ASEAN Digital Ministers' Meeting on 2 February 2024 (Rajah & Tann summary).
- An **Expanded Guide for generative AI** followed in January 2025 (ASEAN).

Seven principles as three questions

Ask	Principles	In plain words
Can we trust it?	Transparency and explainability; Robustness and reliability; Security and safety	We can explain how it reaches results; it works consistently; it is protected and causes no harm
Is it fair to people?	Fairness and equity; Human-centricity	It does not discriminate; it serves people and keeps humans in control
Who answers for it and its data?	Privacy and data governance; Accountability and integrity	Personal data is protected; a named person or office is responsible

What can go wrong with generative AI

The Expanded Guide names six risks:

Risk	What it looks like in an office
Mistakes and anthropomorphism	Confident but wrong answers; trusting the tool as if it were a person
Inaccurate responses and disinformation	Invented facts, laws or citations
Deepfakes, impersonation, fraud and malicious use	A cloned voice of the director asking for an urgent fund transfer
Infringement of intellectual property	Copying protected text or images into official work
Privacy and confidentiality	Citizen or office data typed into public tools
Embedded biases	Unfair results for some groups of people

The Philippine rule: NPC Advisory 2024-04

NPC Advisory 2024-04 (19 December 2024) applies the DPA to AI systems that process personal data. In plain words:

- Tell people how AI is used on their data, and what it means for them.
- The office stays accountable for the results, even when a vendor runs the AI.
- Where automated decisions carry significant risk, a competent person must review them, and people must be able to question and contest them.
- Watch for and reduce bias; keep the data accurate.
- Use only the personal data the AI actually needs.
- Have a lawful basis first. Publicly available data is still protected.
- Let people exercise their rights, such as to object, correct or erase.

Your AI rules at work

Situation	Rule
Drafting a letter with a free public chatbot	Remove names, ID numbers and case details first, or use a tool your office has approved
A tool that ranks or screens applicants	A trained person reviews every decision that affects someone, and applicants can contest it

Situation	Rule
A vendor switches on AI features	Ask what data the feature uses and where it goes before you allow it
An urgent voice or video call from "the director"	Verify through a number you already know before acting

Where did this image come from? Content Credentials

Content Credentials are signed information attached to a file that shows how it was made and edited, and any tampering with them leaves a trace. They follow an open standard (C2PA) that the Expanded Guide points to for content provenance. If an AI tool supports them, they can show that an image was AI-generated. Two limits matter: a file **without** credentials is not proven fake, and a screenshot does not carry the original's credentials (Content Authenticity Initiative FAQ). They are a signal of origin, not a deepfake detector.

Try it 1.2.2A: Write your unit's AI rule (Create, 5 minutes)

Complete the sentence for your own unit:

> In our unit, we may use **[approved tools]** for **[tasks]**. We never enter **[kinds of data]**. Before we use any AI output, **[who]** checks **[what]**. If something goes wrong, we report to **[whom]**.

Try it 1.2.2B: The screenshot experiment (Experiment, 4 minutes)

Your facilitator uploads two sample files to the Content Credentials Verify page: an image that carries credentials, and a screenshot of the same image.

1. Before the result appears, predict what each will show.
2. Compare the results with your prediction.
3. Discuss: what does a missing credential tell you, and what does it not tell you?

Try it later with your own photos, never with office or citizen files.

Check yourself 1.2.2

1. Name the three questions that group the seven principles.
2. A screening tool rejects an applicant, and no one can explain why. Which principle is at stake?
3. Does a missing content credential prove that an image is fake?

Bring it home: apply it in your own office

These three tasks turn the lessons into action. They are not graded, but the data map feeds this afternoon's risk assessment and the commitments feed the closing action plan on Day 3. Use your own office in your notes, but do not share real details in the session.

1. Map one process you handle (Create, 15 minutes)

Pick one process you know well, such as receiving applications, paying out assistance or hiring. Follow one person's data through its life:

Stage	What data?	Where is it kept?	Who can see it?	For how long?	Weak point and one fix
Collect					
Store					
Use					
Share					
Keep					
Dispose					

Then test it against Tell, Legit, Little: is every field needed, used only for its purpose, and explained in a privacy notice?

2. Readiness mini-check (Evaluate, 10 minutes)

Based on the priority measures in the September 2026 DICT and CICC advisory, plus the 2023 case's lesson on lapsed licences. Tick what your office can show today:

- [ ] We know our most serious cyber risk, and the head of office knows it too.
- [ ] Administrator and email accounts use multi-factor authentication.
- [ ] Critical security updates are applied, and antivirus and other licences are renewed before they expire.
- [ ] Only the systems that must be on the internet are on it.
- [ ] Someone watches the logs or alerts and knows what to do with them.
- [ ] We restored a backup successfully in the last six months.
- [ ] We know which vendors can reach our systems or data, and we review that access.
- [ ] Staff know how to report an incident, and to whom.
- [ ] We tested our incident response and continuity plans this year.

Each unticked box is a candidate for your 30-day commitments.

3. My three commitments for the next 30 days (Create)

#	I will...	By (date)	I will know it worked when...
1			
2			
3			

Examples: turn on MFA for my email; ask my DPO for our breach reporting procedure; shred the printed lists in my drawer; propose an AI-use rule for my unit.

Desk card: Module 1 on one page

Print this page and keep it near your workstation.

Remember	What it means	What you do
Secret, Correct, Ready	Confidentiality, integrity, availability	Ask: what if it leaks, changes, or is gone for a week?
Five doors	Phishing, old systems and lapsed licences, exposed websites, shared accounts, personal apps	Pause on urgent messages; one account per person; approved tools only
Data in trust	Personal data belongs to the citizen; you hold it for a purpose	Use it only for that purpose and account for it
Tell, Legit, Little	Transparency, legitimate purpose, proportionality	Tell people, use it only for the stated purpose, collect and keep only what is needed
Government rules	Clearance to access; head's approval within 2 business days to take data off-site; 1,000 records at a time; encrypt	Never take records home without written approval and encryption
3S	Sensitive, Stolen, Serious	All three true: the office must notify the NPC and the people affected
72-5	72 hours to notify the NPC and people; full report in 5 days from discovery	Report to your DPO or IT at once, even if unsure

Remember	What it means	What you do
Rules, People, Places, Tech	ISO 27001 Annex A themes: 37, 8, 14, 34 = 93 controls	Find your role in each theme
Three AI questions	Can we trust it? Is it fair? Who answers for it?	No personal data in public AI tools; a human checks every decision about a person

Glossary in plain words

Term	Plain meaning
Asset	Anything of value to the office: data, systems, devices, people, reputation
Availability	Information and systems are ready when needed
Breach response team	The office team that handles a personal data breach; it includes at least one person who can make urgent decisions
CIA triad	Confidentiality, integrity, availability: Secret, Correct, Ready
Confidentiality	Only authorized people can see the information
Content Credentials	Signed information attached to a file that shows how it was made and edited
Data Protection Officer (DPO)	The person accountable for the office's compliance with the Data Privacy Act
Data subject	The person the data is about
DBNMS	The NPC's online system for breach notifications and annual incident reports
Deepfake	Fake but realistic video, audio or images made with AI
Defacement	Changing a website so it shows an attacker's message
Encryption	Scrambling data so only someone with the key can read it
Extortion	Threatening to publish stolen data unless paid

Term	Plain meaning
Generative AI	AI that produces text, images, audio or video, such as chatbots
Hacktivist	An attacker who acts for a political or social cause
Identity fraud	Using someone's personal details to pretend to be them
Integrity	Information stays correct and unaltered
ISMS	Information security management system: an organized, yearly way to manage security
Multi-factor authentication (MFA)	Proving it is you with two things, such as a password and a code on your phone
NPC	National Privacy Commission, the regulator under the Data Privacy Act
Patch	A software update that fixes a weakness
Personal data breach	A security failure that loses, destroys or alters personal data, or lets someone see or take it without authority
Personal information controller (PIC)	The office that decides what personal data is collected and why
Personal information processor (PIP)	A party that handles personal data for the PIC, on its instructions
Phishing	A fake message that tricks you into clicking, opening a file or giving information; by text it is called smishing
Ransomware	Malicious software that locks files and demands payment
Security incident	Any event that affects or could affect data protection, including near misses
Sensitive personal information	Personal information the law protects more strictly, such as health, age, religion and government ID numbers
Statement of Applicability (SoA)	The ISO 27001 list of controls an office applies or excludes, with reasons

Answers

Try to answer before you read these. Activity answers are model answers: a different answer with a sound reason can also be right.

Lesson 1.1

Check yourself

1. Confidentiality is Secret, integrity is Correct, availability is Ready.
2. Correct (integrity), because the content was changed. Ready (availability) can suffer too if citizens cannot use the real page.
3. No one can tell who did what, the password spreads beyond control, and you cannot remove one person's access without changing it for everyone.
4. Money. More than half of attacks with a known motive involve extortion or ransomware.

Try it 1.1A (model answers)

RSSO asset	Most likely threat	Hit first	One thing we would do
Applicant database	Data theft using stolen passwords	Secret	MFA and access only for staff who need it
Payout list	E-wallet numbers changed by a fraudster or insider	Correct	Two-person approval and call-back before any change
Assistance Portal	Ransomware, or traffic floods that crash it	Ready	Tested backups and a continuity plan
Office email	Phishing	Secret, then everything the account can reach	MFA, a report button, training
Public website	Defacement	Correct	Updates, a protected admin page, monitoring
Backup drive	Ransomware reaching the backups, or theft	Ready, and Secret if stolen	An offline copy, encryption, regular restore tests

Try it 1.1B

1. Door 2: the antivirus subscription had expired in April 2023, and its renewal was delayed by procurement.

2. Ready first: the website and online services went down. Secret next: stolen files were published.
3. First assessments can be wrong. The law requires notice on knowledge or reasonable belief, using what you know, so waiting for certainty is not safe.
4. Report expiry warnings and unusual system behaviour, avoid suspicious links, plan renewals ahead in procurement, and warn citizens about phishing that uses leaked data.

Lesson 1.2

Check yourself

1. Transparency, legitimate purpose and proportionality.
2. Any two of: age, marital status, race or ethnic origin, religious or political affiliation, health, education, offenses, and government-issued numbers such as social security numbers.
3. Sensitive (or usable for identity fraud), Stolen (reason to believe someone unauthorized got it), Serious (real risk of serious harm).
4. When the office knows, or reasonably believes, that a breach happened. Certainty is not required.
5. Written approval from the head (decided within 2 business days; no answer means no), no more than 1,000 records at a time, and encryption. He cannot take all 1,500 at once.

Try it 1.2A

1. P.
2. S: a government-issued number.
3. S: health information.
4. N: information about a government employee's position (Sec. 4(a)).
5. S: age and marital status.
6. P. It is not on the sensitive list, but an e-wallet number can be used for fraud, so treat it as high risk in the 3S test.
7. N: not personal information if no one can be identified from the totals. Be careful with very small counts, which can point to one person.

Try it 1.2B

1. Not compliant. Anyone with the link can see ID numbers. If the link was opened by people with no right to it, this is likely a notifiable breach.
2. Not compliant. Personal email is outside the office's control and its access rules; payroll data may include sensitive information.

3. Not compliant. Data taken off-site must be encrypted (Sec. 23). With sensitive HR data and likely harm, the 3S test points to notification.
4. Not compliant. The office stays responsible for what its vendors do (Secs. 14 and 21). The vendor needs a written agreement that sets its duties, and only the access its job needs.
5. Not compliant, unless the tool is approved and the personal data is removed first. Pasting letters into a public tool discloses them to a third party.
6. It depends. Without personal data it is not a personal data breach, so there is no NPC notice. It is still a security incident: document it, fix it, check other systems, and report it under DICT's reporting mechanism.

Try it 1.2C

1. Lean towards notifying. E-wallet numbers can enable fraud, an unauthorized person received the list, and 230 people are involved; the recipient's promise lowers the risk but cannot be checked. Notify the NPC within 72 hours, document the recipient's confirmation, and consider telling the people affected to watch their accounts. The breach response team and DPO make the final call.
2. Usually not notifiable. Strong encryption with the key kept separate makes the data unreadable, so serious harm is unlikely. Still record it as an incident, wipe the laptop remotely if possible, and write down why you decided. If the password was taped to the laptop, the answer changes.
3. Not notifiable on these facts: it is an availability breach with no sign that data left. Document it, keep investigating, and report the cybersecurity incident to DICT. Many ransomware groups copy data before locking it, so if new evidence shows data was taken, the 72-hour clock starts when you learn it.

Lesson 1.2.1

Check yourself

1. Organizational (Rules) 37, People 8, Physical (Places) 14, Technological (Tech) 34.
2. Which Annex A controls the office applies, which it does not, and why.
3. Clause 9, Performance evaluation.

Try it 1.2.1: 1. Rules (access rights end when the contract ends). 2. People (awareness and training, 6.3). 3. Places (physical security). 4. Tech (use of cryptography, 8.24). 5. Rules (inventory of information and assets, 5.9).

Lesson 1.2.2

Check yourself

1. Can we trust it? Is it fair to people? Who answers for it and its data?
2. Transparency and explainability. Accountability is also at stake, and under NPC Advisory 2024-04 the applicant must be able to contest the decision.
3. No. It only means the origin is unknown. Screenshots and many re-saved files carry no credentials.

Try it 1.2.2B: the original shows who made and edited it; the screenshot shows no content credential. A missing credential tells you nothing about whether a file is real or fake.

Quiz 1

Quiz 1 has 15 items in 20 minutes, closed book, one attempt, and is worth 10% of your grade: threats and impact (5 items), the Data Privacy Act (6), ISO/IEC 27001 (3) and the ASEAN AI guide (1). Twelve items are multiple choice, three of them short scenarios, and three are true or false. Face-to-face, scan the QR code on the screen; online, use the link in the chat. The Check yourself questions and the desk card are the best way to prepare.

Where each fact comes from

Every fact in this guide was checked against these sources on 19 October 2026. Laws and NPC issuances can change; check the NPC and DICT websites for updates.

Laws and regulations

- Republic Act No. 10173, Data Privacy Act of 2012 (full text): definitions, scope, principles, lawful processing, rights, security, government rules and penalties
- Implementing Rules and Regulations of RA 10173, as amended (NPC)
- NPC Circular 16-03, Personal Data Breach Management: breach types, the notification test, 72 hours, 5 days, records
- NPC Circular 2023-06, Security of Personal Data: NPC announcement and NPC FAQ
- NPC Advisory 2026-02, submission of breach notifications through the DBNMS
- NPC, the Data Breach Notification Management System
- NPC, Rights of a Data Subject
- NPC Circular 2022-01, Guidelines on Administrative Fines (summary)
- NPC Advisory 2024-04 on AI systems processing personal data
- Executive Order No. 58 (2024), National Cybersecurity Plan 2023-2028 (summary) and Inquirer report
- DICT department circulars of 2024 (list); National Administrative Register: Department Circular 004 and Department Circular 005

Standards and guides

- ISO/IEC 27001:2022 Annex A: Scrut and CertPro control list
- ISO/IEC 27701:2025 as a standalone standard (Kiwa)
- ASEAN Guide on AI Governance and Ethics (Rajah & Tann summary)
- Expanded ASEAN Guide on AI Governance and Ethics: Generative AI
- Content Credentials and the Content Authenticity Initiative FAQ

Cases and figures

- Case studies (2023 and September 2026): public news reports and official statements. To keep the agencies anonymous, the resource person holds these sources and can show them on request.
- The DICT and CICC joint advisory of 8 September 2026, as reported by Newsbytes on 10 September 2026
- Microsoft Digital Defense Report 2025: Microsoft, 22 Oct 2025; Interaksyon, 3 Nov 2025; eSecurityPlanet

This guide is training material, not legal advice. For a decision about your own office, consult your DPO, your legal officer or the NPC.